

## Criptografía y Seguridad 2025 1Q (72.44)

### Parcial 2

| Ej. 1 | Ej. 2 | Ej. 3 | Ej. 4 | Ej. 5 | Nota |
|-------|-------|-------|-------|-------|------|
| 2     | 2     | 2     | 2     | 2     |      |

#### Reglamento:

- Las respuestas que no se ajusten al enunciado serán rechazadas.
- La condición de aprobación es sumar 6 puntos.
- El examen dura 120 minutos, de 16:00 a 18:00 hs.
- Si creen que alguna pregunta presenta una inconsistencia, asuman la corrección que crean necesaria para dar una respuesta a cada ejercicio. Sumará cero puntos una respuesta de la forma: "Está mal la pregunta".
- El examen se evalúa por lo escrito. Revisar muy bien que las justificaciones y el desarrollo de los ejercicios estén claramente explicados y en el orden correcto.
- Pueden preguntar sin problemas durante el examen para clarificar dudas sobre las preguntas. Las respuestas otorgadas no representan ningún tipo de compromiso y queda a criterio del alumno cómo utiliza esa información.
- Apelamos al código de ética firmado oportunamente por cada alumno en la Universidad.
- De verificar alguna inconsistencia en las respuestas la nota del examen se confirmará en un coloquio complementario.

#### Ejercicios

1. Una aplicación de gestión de sueldos está implementada en un modelo de tres capas. El frontend, el backend y la base de datos. El backend es responsable de definir las reglas que cosas puede hacer un usuario con sus datos y protege la integridad de los mismos con un modelo Clack-Wilson.

Por política de la empresa, ningún empleado debe poder ver el salario de otro empleado.

Para asegurar que ningún empleado pueda acceder a los registros de otro usuario, cada usuario tiene una cuenta definida en la base de datos y la base de datos usa ROW LEVEL security.

Al loguearse en la aplicación, el backend usa esas mismas credenciales para conectarse a la base de datos mientras dura la sesión del usuario.

- a) Si la empresa tiene una única red sin firewalls o equipos que restrinjan las comunicaciones, ¿Cuál es la principal desventaja que ve en la arquitectura original?
- b) Proponga dos mejoras que mantengan el cumplimiento de la política de seguridad.
- c) Compare la arquitectura original y su propuesta. ¿Considera que su propuesta reduce el riesgo de un ataque tipo Man in the Middle efectivo?

2. Responder la opción más correcta.

- ¿Cuál de los siguientes NO es un componente del modelo de DevOps?
  - Seguridad de la Información
  - Desarrollo de Software
  - QA, Control de Calidad del Software
  - Operaciones de IT
- ¿Cuál de los siguientes esquemas provee tolerancia a fallas en sistemas de almacenamiento?
  - Balanceo de Carga
  - Sistema RAID
  - Clustering
  - Pares HA
- ¿Cuál de las siguientes estrategias no tendría sentido en un ataque CSRF?
  - Verificar si la información extra del request fue generada de manera legítima.
  - Evitar que los request puedan realizarse por GET.
  - Banear la IP de quien dispara el request.
  - Concientizar a los usuarios sobre el phishing y el cuidado al clickear en enlaces.

3. José Del Río, un cryptobro, afirma que si un atacante puede probar  $10^4$  passwords por segundo, y las passwords están compuestas por símbolos en  $[a-zA-Z0-9]$ , entonces las passwords deberían tener 5 símbolos y 5 bits de SALT para que la probabilidad de adivinarlas en el lapso de un año sea menor a 0,5.

- a) Explicar si esta afirmación es correcta o no y probar por qué.
- b) José viene recargado y plantea que va a implementar un sistema de autenticación multicanal donde además el segundo canal por SMS se va a poder utilizar para recuperar el password. Comentar que eventual problema tiene esta estrategia y qué aspecto de autenticación multicanal no cumple.

4. Considerar un esquema de secreto compartido de Shamir  $(k, n) = (3, 4)$  en  $\mathbb{Z}_7$ , con el conjunto de sombras  $C = \{(1, 6), (2, 1), (3, 0), (4, 3)\}$ .

- a) Recuperar el secreto.
- b) Cuál es el polinomio generador.
- c) Analizar el esquema desde la perspectiva del análisis de entropía y flujo de información.

5. Para controlar el avance del deep fake, la ONU establece una organización internacional que se va a encargar de escrutinar las redes sociales y medios masivos para producir contenido serio que aporte una mirada objetiva sobre las noticias falsas que circulan. Asumiendo que son los CSO de esta incipiente organización, estructurar y modelar como podría ser el esquema para administrar permisos del sistema interno para el manejo de las publicaciones. Asignar los roles que crean pertinentes y sus competencias.